

FIREWALL DASHBOARD

Gestión de reglas de iptables con panel web, sobre una VM Linux aislada

Proyecto de portfolio de ciberseguridad defensiva · Mario Pérez López

Firewall Dashboard es una aplicación web para definir, aplicar y auditar reglas de iptables sobre una VM Ubuntu, sin depender de la línea de comandos. El objetivo era construir, y poder explicar en detalle, una herramienta que traduce la entrada de un formulario web en comandos privilegiados de sistema sin que eso sea una vulnerabilidad.

Decisiones de diseño

El diseño se apoya en cuatro decisiones. La base de datos manda: cada regla registra quién la creó, cuándo y por qué, algo que no cabe en una tabla de iptables, así que SQLite es la fuente de verdad y el sistema se reconstruye desde ahí. La aplicación nunca toca INPUT, OUTPUT ni FORWARD directamente: crea sus propias cadenas, FWDASH_INPUT, FWDASH_OUTPUT y FWDASH_FORWARD, con un único salto hacia cada una, y aplicar siempre significa lo mismo, vaciar y reconstruir entera desde la base de datos. Los privilegios se resuelven con CAP_NET_ADMIN vía systemd en vez de sudo, que en la práctica equivaldría a acceso de root. Y todo esto se probó primero sin tocar una sola regla real: un firewall simulado en memoria permitió construir y demostrar la aplicación entera en el host antes de acercarse a la VM.

Seguridad por diseño: la contención contra inyección de comandos

Es la amenaza principal de un sistema que convierte formularios web en comandos de sistema privilegiados. Se aborda con cinco capas independientes, ninguna suficiente por sí sola, y dos de ellas reforzadas por un test que falla en CI si alguien las rompe:

- `subprocess.run(argv, shell=False)`: argumentos siempre en lista; la inyección deja de ser posible por construcción.
- El acceso a `subprocess` vive en un único archivo del repositorio.
- Allowlist explícita de binarios ejecutables.
- Un tipo de datos inmutable (`RuleSpec`) que se autovalida al construirse: no existe ruta de código capaz de fabricar una regla inválida.
- Normalización canónica de IPs y puertos antes de tocar la red.

Capturas del sistema

Recorrido completo: crear una regla en el navegador, ver un drift detectado, revisar el preview antes de aplicar, y confirmar el resultado directamente en el kernel de la VM.

firewall-dashboard

● en sincronía

iptables

hace 12 segundos

adminadminSalir

INPUTOUTPUTFORWARD

Buscar en nombre y descripción...

Activas e inactivas ↕

Aplicar...Nueva regla

#	NOMBRE	ACCION	PROTO	ORIGEN	DESTINO	ESTADO	PAQUETES	BYTES	ACTIVA	
10	Drop scan 22	DROP	tcp	0.0.0.0/0	:22	● aplicada	0	0 B	☒	EditarBorrar
20	SSH LAN	ACCEPT	tcp	192.168.252.0/24	-	● aplicada	0	0 B	☒	EditarBorrar
30	Bloq sus range	DROP	all	203.0.113.0/24	-	● aplicada	0	0 B	☒	EditarBorrar

3 regla(s) en INPUT

firewall-dashboard

● drift iptables hace 15 segundos

adminadminSalir

El firewall no coincide con la base de datos. Alguien lo ha tocado por fuera.

• INPUT

```
-A FWDDASH_INPUT -s 198.51.100.99/32 -j DROP
```

La base de datos manda (ADR-0001): «Aplicar» reconstruye las tres cadenas y borra lo que no salga de ella.

INPUTOUTPUTFORWARD

Buscar en nombre y descripción...

Activas e inactivas

Aplicar...

Nueva regla

firewall-dashboard

en sincronía

iptables

ahora

admin

admin

Salir

INPUT

OUTPUT

FORWARD

#

NOMBRE

10

Drop scan 22

20

SSH LAN

30

Bloq sus range

3 regla(s) en INPUT

Aplicar la política al firewall

×

Se vaciarán y reconstruirán las tres cadenas gestionadas. Estos son los 15 comandos que se ejecutarán, en este orden:

INPUT 3 regla(s) de usuario

```
iptables -F FWDASH_INPUT
iptables -A FWDASH_INPUT -m conntrack --ctstate RELATED,ESTABLISHED -m comment --comment fwdash:guardian:conn
iptables -A FWDASH_INPUT -i lo -m comment --comment fwdash:guardian:loopback -j ACCEPT
iptables -A FWDASH_INPUT -s 192.168.252.0/24 -p tcp --dport 8000 -m comment --comment fwdash:guardian:managem
iptables -A FWDASH_INPUT -s 192.168.252.0/24 -p tcp --dport 22 -m comment --comment fwdash:guardian:ssh -j AC
iptables -A FWDASH_INPUT -p tcp --dport 22 -m comment --comment 'fwdash:aaab9f36:Drop scan 22' -j DROP
iptables -A FWDASH_INPUT -s 192.168.252.0/24 -p tcp -m comment --comment 'fwdash:47a9cace:SSH LAN' -j ACCEPT
iptables -A FWDASH_INPUT -s 283.0.113.0/24 -m comment --comment 'fwdash:ea37fb5:8loq sus range' -j DROP
```

OUTPUT 0 regla(s) de usuario

```
iptables -F FWDASH_OUTPUT
iptables -A FWDASH_OUTPUT -m conntrack --ctstate RELATED,ESTABLISHED -m comment --comment fwdash:guardian:con
iptables -A FWDASH_OUTPUT -o lo -m comment --comment fwdash:guardian:loopback -j ACCEPT
iptables -A FWDASH_OUTPUT -d 192.168.252.0/24 -p tcp --sport 8000 -m comment --comment fwdash:guardian:manage
iptables -A FWDASH_OUTPUT -d 192.168.252.0/24 -p tcp --sport 22 -m comment --comment fwdash:guardian:ssh -j A
```

FORWARD 0 regla(s) de usuario

```
iptables -F FWDASH_FORWARD
iptables -A FWDASH_FORWARD -m conntrack --ctstate RELATED,ESTABLISHED -m comment --comment fwdash:guardian:co
```

Cancelar

Aplicar ahora

```

firewall-dashboard % multipass exec firewall-lab -- sudo iptables -S FWDASH_INPUT
multipass exec firewall-lab -- sudo iptables -L FWDASH_INPUT -v -n -x --line-numbers
-N FWDASH_INPUT
-A FWDASH_INPUT -m conntrack --ctstate RELATED,ESTABLISHED -m comment --comment "fwdash:guardian:contrack" -j ACCEPT
-A FWDASH_INPUT -i lo -m comment --comment "fwdash:guardian:loopback" -j ACCEPT
-A FWDASH_INPUT -s 192.168.252.0/24 -p tcp -m tcp --dport 8000 -m comment --comment "fwdash:guardian:management" -j ACCEPT
-A FWDASH_INPUT -s 192.168.252.0/24 -p tcp -m tcp --dport 22 -m comment --comment "fwdash:guardian:ssh" -j ACCEPT
-A FWDASH_INPUT -p tcp -m tcp --dport 22 -m comment --comment "fwdash:aaab9f36:Drop scan 22" -j DROP
-A FWDASH_INPUT -s 192.168.252.0/24 -p tcp -m comment --comment "fwdash:47a9cace:SSH LAN" -j ACCEPT
-A FWDASH_INPUT -s 203.0.113.0/24 -m comment --comment "fwdash:ea37f5e5:Blog sus range" -j DROP
Chain FWDASH_INPUT (1 references)
num      pkts      bytes target     prot opt in     out     source                destination
1         0        0 ACCEPT     0      * * *      0.0.0.0/0            0.0.0.0/0            ctstate RELATED,ESTABLISHED /* fwdash:guardian:contrack */
2         0         0 ACCEPT     0      * lo *      0.0.0.0/0            0.0.0.0/0            /* fwdash:guardian:loopback */
3         7        448 ACCEPT     6      * * *      192.168.252.0/24      0.0.0.0/0            tcp dpt:8000 /* fwdash:guardian:management */
4         4        256 ACCEPT     6      * * *      192.168.252.0/24      0.0.0.0/0            tcp dpt:22 /* fwdash:guardian:ssh */
5         0         0 DROP       6      * * *      0.0.0.0/0            0.0.0.0/0            tcp dpt:22 /* fwdash:aaab9f36:Drop scan 22 */
6         0         0 ACCEPT     6      * * *      192.168.252.0/24      0.0.0.0/0            /* fwdash:47a9cace:SSH LAN */
7         0         0 DROP       0      * * *      203.0.113.0/24        0.0.0.0/0            /* fwdash:ea37f5e5:Blog sus range */

```

4. Verificación cruzada. La misma regla vista en iptables -S dentro de la VM

Estado y stack

Bloques A (aplicación completa) y B (capa de iptables real, privilegios, auto-bloqueo provocado y medido) cerrados. Bloque C (interconexión end-to-end) en curso, con el recorrido navegador → API → iptables ya medido de punta a punta.

FastAPI · SQLAlchemy 2.0 · Alembic · SQLite · React 18 · TypeScript · Vite · pytest · ruff · mypy · bandit

Repositorio: github.com/Mariio09/firewall-lab